信息安全测评与风险评估

8.3 脆弱性识别与赋值

授课教师：张玉



目录

CONTENTS

01 第一节课导入——案例：一个被遗忘的账号

02 学习目标（第一节课）

03 什么是脆弱性？

04 脆弱性识别的目的

第一节课导入——案例：一个被遗忘的账号

引入问题 **威胁是“谁想攻击你”，脆弱性是“你身上哪里有伤口”——不知道伤口在哪，怎么防御？**

案例素材

2021年5月，美国最大成品油管道公司Colonial Pipeline遭勒索攻击，整条管道停摆一周，最终支付440万美元赎金。攻击起点不是零日漏洞，而是一个不再使用却依然有效的VPN账号——离职没注销，且无多因素认证。

核心问题

- 为什么一个早已不再使用、只值“中危”的账号，能放倒一家行业巨头？

公司存在的脆弱性

序号	脆弱性问题	
1	离职员工VPN账号未注销	
2	VPN仅单因素认证，口令疑已泄露	
3	对“僵尸账号”缺乏定期审计清理	
4	备份恢复演练不足	
5	内网缺乏分段隔离，横向移动无阻	

结论 威胁总会利用脆弱性。识别脆弱性就是“找到自己身上的伤口”——这是风险评估的核心环节。

学习目标（第一节课）

通过本次课的学习，你将能够：

理解

脆弱性的定义及其在风险评估中的地位

掌握

脆弱性识别的三种主要方法

能够

从技术层面识别各类脆弱性（物理层/网络层/系统层/应用层）

能够

使用常用工具辅助识别技术脆弱性

什么是脆弱性？

GB/T 20984-2022 定义

脆弱性是资产中存在的、可能被威胁利用的弱点或缺陷，包括技术脆弱性和管理脆弱性。

核心理解

- 脆弱性是资产本身存在的弱点
- 没有威胁时，脆弱性不会造成损害

威胁 + 脆弱性 = 安全事件

（威胁利用脆弱性才造成危害）

概念	比喻	说明
资产	一栋大楼	需要保护的对象
威胁	盗贼	想要破坏/窃取的主体
脆弱性	大楼上的窗户没有锁	资产本身的缺陷

脆弱性识别的目的

找到系统中所有可能被威胁利用的“薄弱环节”。

脆弱性识别的工作目标：

- **识别** → 找出系统中存在的所有脆弱性
- **分类** → 区分技术脆弱性和管理脆弱性
- **赋值** → 评估每个脆弱性的严重程度
- **关联** → 分析脆弱性与资产的对应关系

重要性：

脆弱性是风险计算的**核心输入要素**

脆弱性识别不全面 →**风险评估不准确**→整改不到位

“木桶效应”中最短的那块板，往往就是**脆弱性最集中**的地方

脆弱性识别的三种方法

方法	说明	适用场景	优缺点
问卷调查	向资产所有者、使用者发放问卷	管理脆弱性识别	☑ **覆盖面广** ✗ 依赖受访者配合
工具检测	使用漏洞扫描、配置核查工具	技术脆弱性识别	☑ **效率高** ✗ 只能发现已知漏洞
人工核查	文档查阅、人员访谈、现场观察	技术+管理脆弱性	☑ **深入** ✗ 耗时较长

综合应用：实际工作中三种方法结合使用，取长补短。

脆弱性识别的对象与分类

GB/T 20984-2022 将脆弱性分为两大类：技术脆弱性和管理脆弱性

技术脆弱性 — 涉及各个技术层面：

序号	识别对象	识别内容
1	物理环境	机房场地、防火、供配电、防静电、接地防雷、电磁防护、通信线路保护
2	网络结构	网络结构设计、边界保护、访问控制策略、网络设备安全配置
3	主机系统（含操作系统）	物理保护、用户账号、口令策略、资源共享、事件审计、访问控制
4	数据库	补丁安装、鉴别机制、口令机制、访问控制、备份恢复、审计机制
5	应用系统	审计机制、访问控制策略、数据完整性、通信安全、鉴别机制、密码保护

管理脆弱性 — 分为技术管理和组织管理：

类别	识别内容
技术管理	物理和环境安全、通信与操作管理、访问控制、系统开发与维护、业务连续性
组织管理	安全管理组织、安全管理制度、人员安全管理、资产管理

技术脆弱性（一）—— 物理环境脆弱性

识别对象：机房、数据中心、设备物理环境

序号	检查项	常见脆弱性问题	识别方法
1	机房选址	选在顶层/地下室、靠近强	现场勘察
2	物理访问控制	门禁失效、无访客登记	现场观察
3	防火	无自动灭火系统、消防	查阅+检查
4	供配电	无UPS、无备用发	现场检查
5	防雷接地	无防雷装置、接地不符	检测+查阅
6	防水防潮	屋顶漏水、无漏水	现场观察
7	电磁防护	电源线与信号线未	现场观察
8	设备固定	机柜未固定、设备无标识	现场观察

技术脆弱性（二）—— 网络结构脆弱性

识别对象　网络拓扑、网络设备配置

序号	检查项	常见脆弱性问题	识别方法
1	网络区域划分	未按业务功能分区	查看拓扑图
2	边界防护	无防火墙或策略配置不当	工具检测+核查
3	访问控制策略	存在允许所有宽松策略	核查配置
4	设备安全配置	使用默认密码、无SSH	核查配置
5	单点故障	核心设备无冗余	查看拓扑图
6	远程管理安全	使用Telnet明文管理	核查配置
7	无线接入	未授权AP、弱加密	工具检测

技术脆弱性（三）—— 主机系统脆弱性

识别对象：Windows/Linux服务器

序号	检查项	常见脆弱性问题	识别方法
1	账号管理	默认账号未禁用、存在共享账户	人工核查
2	口令策略	无复杂度要求、密码未定期更换	核查配置
3	登录失败处理	未限制登录失败次数	核查配置
4	最小安装	安装了不必要的组件和服务	人工核查
5	高危端口	开放了不必要的高危端口	工具检测
6	系统补丁	长期未更新补丁（如ZeroLogon漏洞）	工具检测
7	审计日志	未启用或日志不完整	核查配置
8	恶意代码防护	未安装防病毒软件或病毒库过期	人工核查

技术脆弱性（四）—— 数据库脆弱性

识别对象： MySQL、SQL Server、Oracle等

序号	检查项	常见脆弱性问题	识别方法
1	补丁管理	未及时安装安全补丁	工具检测
2	口令机制	默认密码、弱口令	工具检测+核查
3	访问控制	权限分配过宽	核查配置
4	备份恢复	无备份策略或备份未验证	文档查阅
5	审计机制	未开启审计日志	核查配置
6	网络服务设置	暴露不必要的网络服务	工具检测

技术脆弱性（五）—— 应用系统脆弱性

识别对象：Web应用、业务系统

序号	检查项	常见脆弱性问题	识别方法
1	身份鉴别	弱密码策略、无多因素认证	人工验证
2	访问控制	存在越权漏洞	渗透测试
3	数据完整性	传输过程未校验	抓包分析
4	通信安全	未使用HTTPS/TLS	工具检测
5	审计机制	关键操作未记录	核查配置
6	输入验证	存在SQL注入、XSS漏洞	渗透测试

第一节课实践任务1——技术脆弱性识别练习

任务名称

技术脆弱性识别练习

任务场景

教师提供“XX企业系统现状描述”（见素材1）

素材1：技术脆弱性识别表.docx

任务内容

素材2：模拟漏洞扫描报告（片段）.

素材3：模拟信息系统脆弱性数据.do

1. 阅读系统现状描述
2. 对照脆弱性识别清单，找出所有技术脆弱性
3. 标注每个脆弱性所属层面（物理/网络/系统/数据库/应用）
4. 填写《技术脆弱性识别表》

时间安排：**约20分钟**

第一节课实践任务1——《技术脆弱性识别表》

序号	脆弱性描述	所属层面	可能被利用的威胁	初步严重程度
1				
2				
3				
4				
5				
6				
7				
8				

第一节课——小结与过渡

本节课要点回顾：

- **脆弱性定义：**资产中可能被威胁利用的弱点（技术+管理）
- **识别方法：**问卷调查、工具检测、人工核查
- **技术脆弱性五大层面：**物理环境、网络结构、主机系统、数据库、应用系统
- **关键认识：**威胁+脆弱性=安全事件

下节课预告：管理脆弱性识别 + 脆弱性赋值

第二节课导入——管理脆弱性的“杀伤力”

回顾案例

Colonial Pipeline事件中，攻击者能大大方方登录进来，不是因为技术漏洞有多炫，而是因为管理脆弱性：

账号生命周期缺失	→	离职账号未注销
单因素认证	→	一组口令就能进入
备份恢复演练不足	→	只能支付440万赎金

技术脆弱性让攻击者“进得来”，管理脆弱性让攻击者“待得住”。

第二节课学习目标

通过本次课的学习，你将能够：



掌握

管理脆弱性两类四方面的识别内容



能够

运用脆弱性赋值方法（难易程度+影响程度）



能够

独立完成一份完整的脆弱性识别与分析报告

管理脆弱性（一）—— 技术管理脆弱性

技术管理脆弱性：与具体技术活动相关的管理缺陷

子类别	常见脆弱性表现	识别方法
物理和环境安全	机房出入管理制度不完善、环境监控缺失	文档查阅+现场检查
通信与操作管理	无网络变更审批流程、运维记录不完整	文档查阅+访谈
访问控制	权限申请/审批流程缺失、账号回收不及时	文档查阅+核查
系统开发与维护	无代码安全规范、开发与测试环境未隔离	文档查阅+现场核查
业务连续性	无应急预案、未进行应急演练	文档查阅

管理脆弱性（二）—— 组织管理脆弱性

组织管理脆弱性： 与安全管理环境相关的缺陷

子类别	常见脆弱性表现	识别方法
安全管理组织	无专门安全机构、岗位职责不明确	文档查阅
安全管理制度	制度体系不完善、制度未审批发布、版本未控制	文档查阅+访谈
人员安全管理	录用未进行安全审查、离岗权限未回收、未签署保密协议	文档查阅+访谈
资产管理	无资产清单、资产未确权、介质处置不规范	文档查阅+现场检查

管理脆弱性的识别方法

文档查阅

具体操作

审查制度文件、审批记录、培训记录、演练记录

关注点

制度是否完备、是否执行

人员访谈

具体操作

询问安全主管、系统管理员、普通员工

关注点

制度是否了解、是否落实

现场观察

具体操作

检查机房管理、资产标识、介质存放

关注点

管理措施是否实际执行

第二节课实践任务1——管理脆弱性识别练习（20分钟）

任务场景

教师提供“XX企业管理现状描述”（见素材2）

时间安排：**约20分钟**

任务内容

1. 阅读管理现状描述
2. 找出所有管理脆弱性（技术管理+组织管理）
3. 分类填写《管理脆弱性识别表》

素材4：模拟安全管理制度文档片段.d

素材5：管理脆弱性识别表.docx

第二节课实践任务1——《管理脆弱性识别表》

序号	脆弱性描述	类型（技术管理/组织管理）	子类别	可能影响
1				
2				
3				
4				
5				
6				
7				
8				

脆弱性赋值方法（20分钟）

GB/T 20984-2022 脆弱性赋值分为两部分：

第一部分：脆弱性被利用的难易程度

等级	标识	定义
5	很高	攻击者极易利用，无需特殊条件
4	高	攻击者较容易利用，需一定条件
3	中	攻击者可利用，但需特定环境
2	低	攻击者难以利用，需严格条件
1	很低	攻击者几乎无法利用

第二部分：脆弱性被利用后的影响程度

等级	标识	定义
5	很高	对资产造成完全损害（系统瘫痪、数据全丢）
4	高	对资产造成重大损害（业务中断、数据泄露）
3	中	对资产造成一般损害（部分业务受影响）
2	低	对资产造成较小损害（轻微影响）

脆弱性赋值——综合判断示例

脆弱性	被利用难易程度	影响程度	综合严重性	判断依据
核心交换机单台部署	高（4）	高（4）	高（4）	一旦故障，全网中断
弱口令（admin/123456）	很高（5）	中（3）	高（4）	极易被爆破，但影响范围取决于账户权限
未启用审计日志	低（2）	中（3）	中（3）	攻击者不会主动利用，但影响事后追溯

第二节课实践任务2——脆弱性赋值练习（20分钟）

任务名称

脆弱性赋值练习

任务场景

基于任务1中识别的脆弱性，逐项赋值

素材6：脆弱性识别与赋值汇总表.do

素材7：教师演示用——脆弱性赋值

任务内容

1. 对每个脆弱性进行“被利用难易程度”赋值（1–5）
2. 对每个脆弱性进行“影响程度”赋值（1–5）
3. 计算综合严重性
4. **填写《脆弱性赋值表》**

第二节课实践任务2——《脆弱性赋值表》

序号	脆弱性描述	被利用难易程度(1–5)	影响程度(1–5)	综合严重性	赋值理由
1					
2					
3					
4					
5					
6					

脆弱性识别的关键注意事项

脆弱性与威胁的关联

- 威胁总是利用脆弱性才造成危害
- 识别脆弱性时要考虑“可能被什么威胁利用”

已有安全措施的分析

- 已有安全措施可能降低脆弱性被利用的可能性
- 但安全措施本身也可能存在脆弱性（如防火墙策略配置错误）

技术与管理的关系

- 技术脆弱性可能源于管理缺陷
- 管理脆弱性可能加剧技术脆弱性的影响

动态性

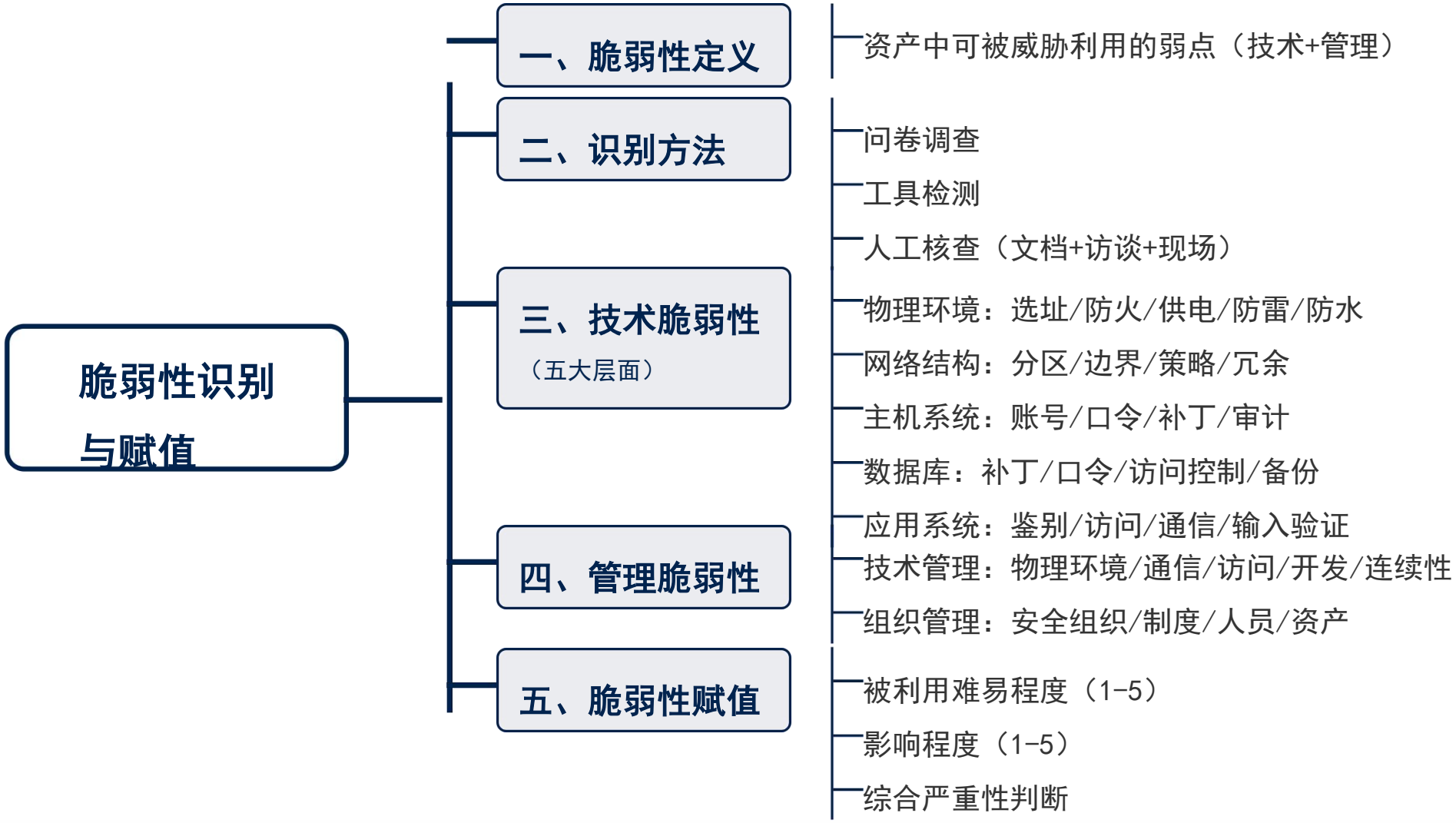
- 漏洞不断被发现，脆弱性不断变化
- 需要定期重新评估

思政融入——脆弱性识别关乎国家安全

知彼知己	**知己**——了解自己的脆弱性，是防御的基础；不知道弱点在哪里，就不可能做好防护。 案例：Colonial Pipeline若定期清理离职账号、启用多因素认证，440万美元赎金本可避免
责　任	脆弱性识别是风险评估中最“接地气”的工作。 每发现一个脆弱性，就是排除一个安全隐患；对国家关键信息基础设施的脆弱性识别，是守护国家安全的重要环节。
工匠精神	脆弱性识别需要细致、全面、不遗漏。 **“差不多”的心态是脆弱性识别的大敌。**

每一次认真的脆弱性识别，都是在为国家网络安全“查漏补缺”。

知识点回顾


脆弱性识别与赋值
一、脆弱性定义
资产中可被威胁利用的弱点（技术+管理）
二、识别方法
问卷调查
工具检测
人工核查（文档+访谈+现场）
三、技术脆弱性
（五大层面）
物理环境：选址/防火/供电/防雷/防水
网络结构：分区/边界/策略/冗余
主机系统：账号/口令/补丁/审计
数据库：补丁/口令/访问控制/备份
应用系统：鉴别/访问/通信/输入验证
四、管理脆弱性
技术管理：物理环境/通信/访问/开发/连续性
组织管理：安全组织/制度/人员/资产
五、脆弱性赋值
被利用难易程度（1-5）
影响程度（1-5）
综合严重性判断

课后作业

必做	完成《技术脆弱性识别表》《管理脆弱性识别表》《脆弱性赋值表》，提交至学习通平台
必做	完成活动8.3在线测试（选择题+判断题，共20题）
选做	调查一个真实的数据泄露事件，分析其中涉及的技术脆弱性和管理脆弱性
预习	预习8.4“风险计算（矩阵法/相乘法）”相关内容

感谢观看

